

IQA Phase 2 AI Security Governance Report

API, feedback, audit trail, incidents, metrics and governance controls

Document type	IQA Phase 2 AI Security Governance Report
Version	3.0
Status	Final Phase 2 update, JAL02, JAL03 and JAL04 validated. IQA2_LIV03 remains open only for notebook update.
Date	17 June 2026
Scope	IQA MLOps Phase 2, validated JAL02, JAL03 and JAL04, remaining IQA2_LIV03 notebook update
Confidentiality	Internal project documentation

Final update after server side PostgreSQL validation of IQA2_JAL02 and project confirmation that IQA2_JAL03 and IQA2_JAL04 are validated.

Contents

Section	Title
1	Executive summary
2	Current status
3	Architecture and trust boundaries
4	Governance rules
5	Threat model continuity
6	Validation evidence
7	JAL02, JAL03 and JAL04 final status
8	Phase 3 security recommendation
9	Notebook and LIV03 handover
10	Evidence register

1. Executive summary

Phase 2 turns the IQA threat model into concrete API contracts, feedback safeguards, scenario isolation, structured errors, security incidents, filtered metrics, audit trail documentation, PostgreSQL metadata persistence and test evidence. The earlier open decision on JAL02 is now closed.

Security governance conclusion

FastAPI remains the governance boundary. PostgreSQL persists runtime metadata. MLflow Registry remains the model source of truth. MinIO stores artifacts but does not decide promotion state. JAL02, JAL03 and JAL04 are validated.

Area	Phase 2 outcome	Evidence
API contracts	scenario_id required, strict request schemas and standardized errors	NAT02, NAT03, NAT12, NAT13
Feedback governance	human_sophie display only, oracle_gt sovereign for train eligibility	NAT04 to NAT07, NAT15, NAT16
Audit and observability	sha256, piece_event_id, scenario_id, model versions, feedback and incidents traceable	NAT09, NAT10, NAT11, NAT14, NAT17
Metadata persistence	PostgreSQL live metadata schema and write through validated	JAL02, 9 live PostgreSQL tests passed
Milestone closure	JAL03 and JAL04 validated	Project planning update and team confirmation

2. Current status

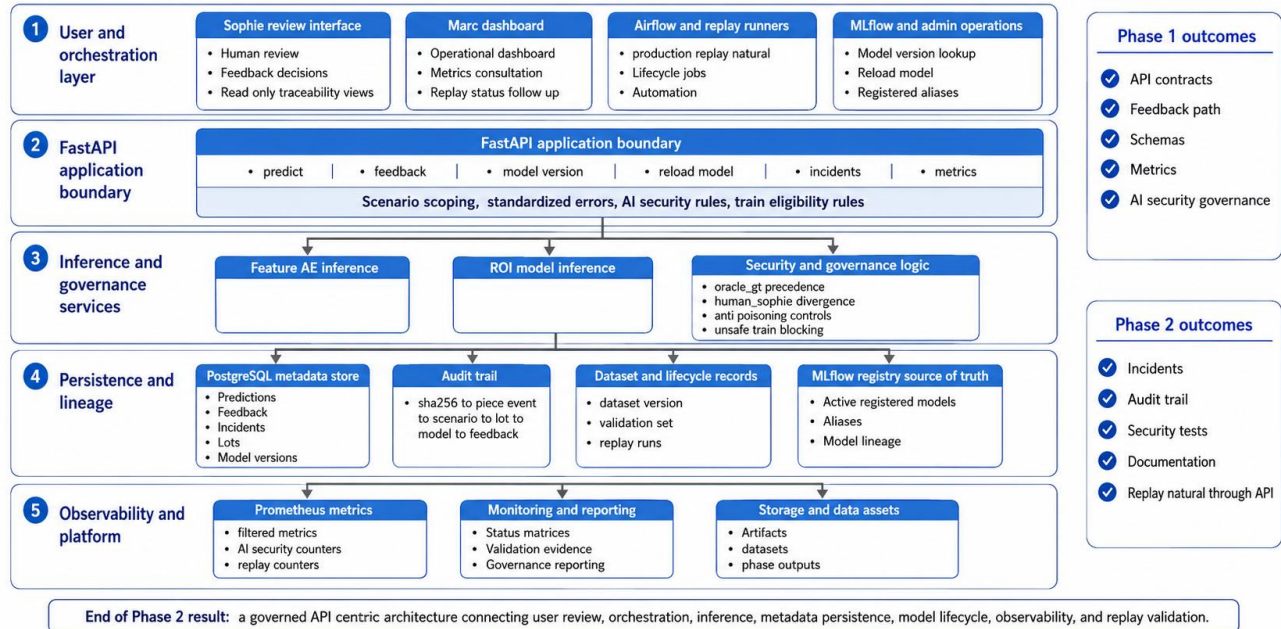
Item	Status	Comment
NAT01 to NAT17	Validated	Merged and validated through local and server checks.
IQA2_JAL02	Validated at 100%	production_replay_natural validated through API, feedback, reload events and live PostgreSQL metadata store.
IQA2_JAL03	Validated	Completed in the Phase 2 delivery narrative.
IQA2_JAL04	Validated	Completed in the Phase 2 delivery narrative.
IQA2_LIV03	Open	Notebook update remains before final deliverable closure.

3. Architecture and trust boundaries

The corrected architecture remains: user interfaces or Airflow call FastAPI; FastAPI calls inference; inference returns a decision; FastAPI writes metadata and exposes metrics. Inference does not write directly to the metadata store. Prometheus scrapes metrics rather than receiving active pushes.

IQA project architecture at the end of Phase 2

What was delivered in Phase 1 and Phase 2



Boundary	Rule	Security reason
FastAPI	Primary governance boundary	High impact state changes pass through schemas, guards, incidents and audit logic.
Inference service	No direct metadata write	Prevents bypassing API validation and governance rules.
PostgreSQL	Runtime metadata persistence	Stores predictions, feedback, incidents, lots, reload events and model versions.
MLflow Registry	Model state source of truth	Registry aliases decide active model references and reload decisions.
MinIO	Passive artifact store	Stores artifacts, heatmaps and datasets, but never promotion authority.

4. Governance rules

Governance rule	Phase 2 expression
Traceability first	Every prediction keeps piece_event_id, scenario_id, model_version and audit context.
GT sovereignty	oracle_gt controls training eligibility; human_sophie remains display only.
No unsafe training data	Defective, ROI warning, ROI fail, false negative and validation set samples are blocked.
Scenario isolation	Critical routes require scenario_id and registered models are scoped by scenario.
Reload governance	Admin reload requires token, scenario_id and audit record.
Observable security events	Feedback conflicts, false negatives, ROI failures, unsafe train blocks and reload refusals have counters or incidents.

5. Threat model continuity

The Phase 1 threat model identified risks around prediction, feedback, candidate dataset creation, model promotion, reload, auditability and Feature AE lifecycle integrity. Phase 2 implements practical controls that make those risks visible and enforceable.

Threat	Phase 2 implemented control
Feedback poisoning	Valid prediction id, replay block, oracle_gt train sovereignty and conflict incidents.
Abusive model reload	Admin token, scenario scope, reload refusal audit and incidents.
Invalid prediction request	Required scenario_id, strict schemas, audit trail and standardized errors.

Threat	Phase 2 implemented control
Candidate contamination	Good only, ROI safe validation and unsafe train blocking.
Scenario collision	Scenario required on predict, model version and reload flows.
Secret exposure	Admin and service tokens come from environment; reports avoid secret disclosure.

6. Validation evidence

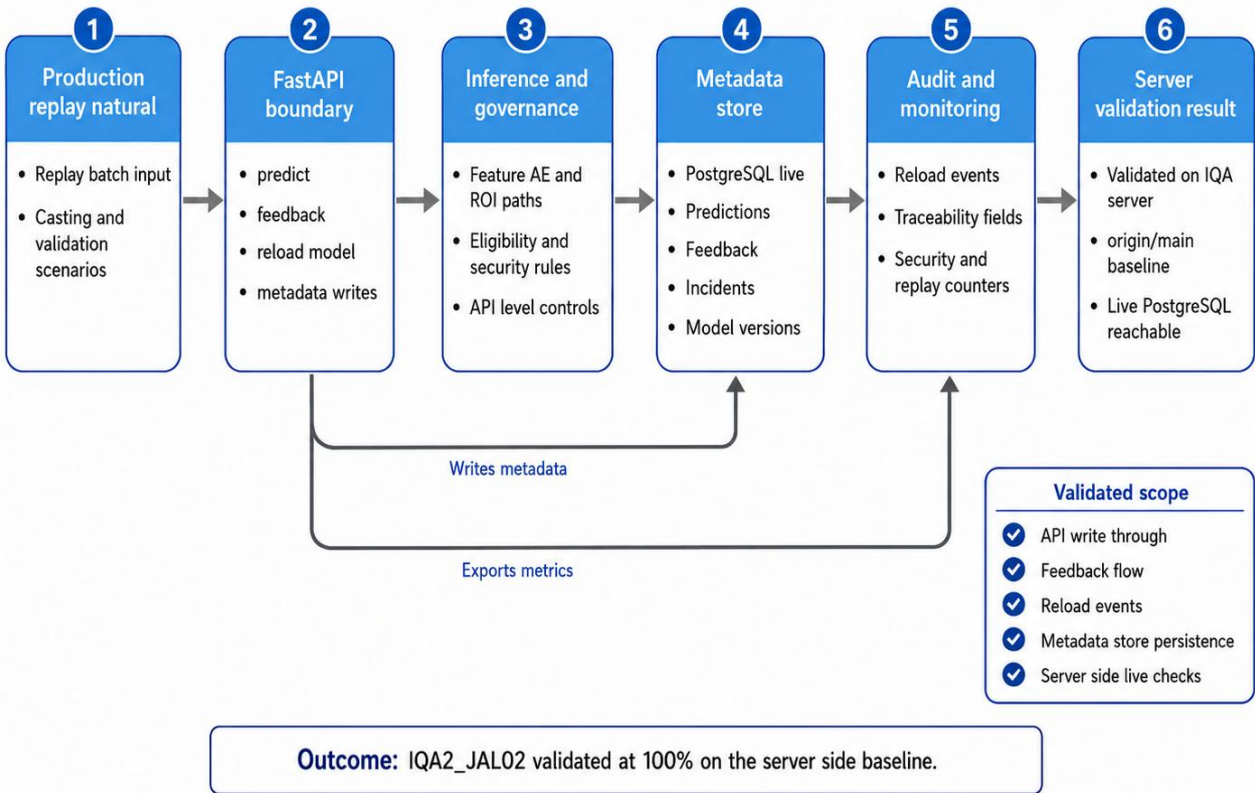
Evidence layer	Result
CubeAI broad baseline	464 passed, 11 skipped, 1 warning after the Phase 2 origin/main resync on CubeAI.
IQA server live PostgreSQL JAL02	POSTGRES_CONNECTION_OK iqa_metadata iqa; IQA metadata schema is initialized; 9 passed in 6.14s.
IQA server stack	IQA server runs Docker Compose services for iqa-api, iqa-inference, Streamlit, Airflow, PostgreSQL, MLflow, Grafana, MinIO, Prometheus and reverse proxy.
IQA server specifications	Ubuntu 24.04.4 LTS, 16 CPU, 39 GiB RAM, RTX 3060 12 GiB VRAM, low load, Docker Compose operational.
GitHub main architecture	.dvc, .github/workflows, airflow/dags, configs, data, deploy, docs, models/manifests, reports, scripts, src/iqa, tests, Dockerfile, dvc.yaml, pyproject.toml and README.md.

7. JAL02, JAL03 and JAL04 final status

This section replaces the former JAL02 decision gate. JAL02 is now closed with live PostgreSQL evidence. JAL03 and JAL04 are reported as passed and validated by the project team. The remaining action is not a milestone gate but a deliverable packaging task: update notebooks for IQA2_LIV03.

IQA2 JAL02 validation schema

Replay naturel branché sur API



8. Phase 3 security recommendation

Phase 3 should add Kong API Gateway as the single entry point in front of FastAPI and the exposed interfaces. It should handle routing, authentication, rate limiting, access logs, security headers and protection of sensitive routes. Kubernetes should move to Phase 4 unless the mentor explicitly requests a limited Phase 3 demonstrator.

Phase 3 security item	Recommended scope
Kong API Gateway	Replace or formalize the current reverse proxy as the governed entry point.
CI/CD	Run tests, lint, security checks and Docker build before deployment.
Airflow E2E	Orchestrate ingestion, replay, training, evaluation, reload and monitoring tasks.
Monitoring	Prometheus and Grafana dashboards for API, replay, AI security counters and service health.
Kubernetes	Phase 4 scalability target, not required for Phase 3 closure.

9. Notebook and LIV03 handover

IQA2_LIV03 should close only after the notebooks are updated with the final Phase 2 status. The notebooks must not keep draft v0.9 assumptions where JAL02 was still open.

- Update notebooks with JAL02 server PostgreSQL live evidence.
- Mark JAL03 and JAL04 as validated.
- Add final architecture and repository architecture views.
- Add Phase 3 decisions: Kong API Gateway, CI/CD, Airflow E2E, monitoring, runbooks.
- Move Kubernetes to Phase 4 unless mentor asks for a limited demo.

10. Evidence register

Evidence	Use
iqa_jal02_server_live_postgres_host_20260617_143652.txt	Final JAL02 live PostgreSQL validation.
iqa_jal02_full_baseline_20260617_141214.txt	Broad CubeAI baseline after repo resync.
iqa_phase3_server_specs_20260617_172308.txt	Server capacity and runtime state used to decide Phase 3 vs Phase 4 scope.
GitHub data-fablab/iqa-mlops	Repository architecture and main branch structure.